Universiteit van Amsterdam
Amsterdam Business School

Cybersecurity Basics & Business Impact

Lecture 1 of the course 'Cybersecurity and IT/AI auditing'

Rob Havermans

Information on this course

Lectures are planned every Tuesday, at Roeters Eiland Campus (REC).

Kriterion: roetersstraat 170, 1018 WE, Amsterdam

REC M: Plantage Muidergracht 12

Lectures	Teacher	Topic	Location
Feb 3, 13:00-15:00	Rob Havermans	Cybersecurity basics & business impact	Kriterion K1
Feb 10, 13:00-15:00	Rob Havermans	Cyber Risk Management & Threat Landscape	REC M1.01
Feb 17, 13:00-15:00	Martijn Dekker	Cybersecurity Controls & Frameworks	REC M1.01
Feb 24, 13:00-15:00	Martijn Dekker	Cybersecurity Governance, Compliance & Regulation	Kriterion K1
Mar 3, 13:00-15:00	Edo Roos Lindgreen	IT Auditing Fundamentals	Kriterion K1
Mar 10, 13:00-15:00	Edo Roos Lindgreen	Auditing in Practivce & Future Trends	Kriterion K1

Information on this course

Tutorials are planned on Thursdays and Fridays.

REC V: Valckeniersstraat 61, 1018 XE, Amsterdam

REC JK: Valckeniersstraat 65-67, 1018 XE, Amsterdam

No prep work is needed for these tutorials. Work is done in the tutorials, mostly in small sub-groups. Therefore, do plan to be present the entire tutorial.

Tutorials	Teacher	Location
Feb 5, 11:00-13:00	Dennis Postma	REC V2.12
Feb 5, 13:00-15:00	Dennis Postma	REC V2.12
Feb 6, 11:00-13:00	Olaf Streutker	REC JK1.83
Feb 6, 13:00-15:00	Olaf Streutker	REC JK1.23
Feb 12, 11:00-13:00	Rini Gopinath	REC V2.12
Feb 12, 13:00-15:00	Rini Gopinath	REC V2.12
Feb 13, 11:00-13:00	Rob Schuurman	REC JK1.83
Feb 13, 11:00-13:00	Rob Schuurman	REC JK1.23
Feb 19, 11:00-13:00	Dennis Postma	REC V2.12
Feb 19, 13:00-15:00	Dennis Postma	REC V2.11
Feb 20, 11:00-13:00	Olaf Streutker	REC JK1.83
Feb 20, 13:00-15:00	Olaf Streutker	REC JK1.23
Feb 26, 11:00-13:00	Rini Gopinath	REC V2.12
Feb 26, 13:00-15:00	Rini Gopinath	REC V2.12
Feb 27, 11:00-13:00	Rob Schuurman	REC JK1.83
Feb 27, 13:00-15:00	Rob Schuurman	REC JK1.23
Mar 5, 11:00-13:00	Dennis Postma	REC V2.12
Mar 5, 13:00-15:00	Dennis Postma	REC V2.12
Mar 6, 11:00-13:00	Olaf Streutker	REC JK1.83
Mar 6, 13:00-15:00	Olaf Streutker	REC JK1.23
Mar 12, 11:00-13:00	Rini Gopinath	REC V2.12
Mar 12, 13:00-15:00	Rini Gopinath	REC V2.12
Mar 13, 11:00-13:00	Rob Schuurman	REC JK1.83
Mar 13, 13:00-15:00	Rob Schuurman	REC JK1.23

Assessment on this course

Assessment will be 100% exam

Agenda

1. Setting the stage: why this matters
2. Positioning cybersecurity correctly
3. Threat landscape overview, what could go wrong ?
4. Why is it so difficult to secure ?
5. Business impacts
6. Real-world case studies
7. Closing: key takeaways for managers

Why are you here ?

A September 2025 cyberattack on Jaguar Land Rover (JLR), attributed to the "Scattered Lapsus$ Hunters" group, severely disrupted production for over a month. Expected total financial impact for JLR is close to 500 mln pounds. The attack forced the closure of UK factories, impacted supply chains, and resulted in confirmed theft of employee data. Total damage to UK economy expected close to 2 billion pounds.

On July 19, 2024, a faulty content update for the CrowdStrike Falcon sensor caused a massive, global IT outage affecting 8.5 million Windows systems. The update led to "Blue Screen of Death" (BSOD) errors, disrupting airlines, hospitals, banks, and media outlets. The incident, not a cyberattack, was due to inadequate testing, requiring manual fixes.

deVolkskrant

Columns Opinie Cartoons Podcasts Cultuur & M

NIEUWS

TU Eindhoven getroffen door cyberaanval, maandag geen onderwijs

Studenten op de TU Eindhoven. Raymond Rutting / de Volkskrant

Jasper Daams
is nieuwsverslaggever van de Volkskrant.
12 januari 2025, 16:03

In January 2025 the University of Eindhoven avoided a major data loss and IT destruction by bringing down all of their systems and network. They were under a ransomware attack and quickly reacted. The network was off-line for approximately one week with major impact on the University's operations.

Dear mr. / mrs. CISO*, welcome in this meeting. We have a question for you. Are we secure ?

CISO = Chief Information Security Officer

Dear mr. / mrs. manager, welcome in this meeting. We have a question for you. How is it that you got hacked ?

Why should managers care?

01

Digital Dependence

Organizations rely heavily on digital systems, making them vulnerable to widespread disruption from cyber incidents.

02

Systemic Exposure

Interconnected systems create systemic risks where a single breach can cascade and affect multiple parts of the organization.

03

Targets of Attacks

Cyber attacks focus on stealing money, compromising sensitive data, damaging trust, and interrupting business continuity.

04

Accountability Rising

Boards and executives are increasingly held responsible for cybersecurity outcomes and risk management.

05

Managerial Role

Managing people, processes, and budgets directly influences cyber risk and the organization's security posture.

Common misconceptions about cybersecurity

Only an IT problem

Cybersecurity is often mistaken as solely an IT issue, but it requires management involvement across all departments.

Tools alone can fix it

Relying only on security tools is inadequate; effective cybersecurity depends on policies, processes, and human behavior.

Only big tech firms affected

Cyber threats impact organizations of all sizes and industries, not just large technology companies.

100% prevention is possible

No system can guarantee total prevention of cyber attacks; the focus should be on risk management and resilience.

Security is a one-time fix

Cybersecurity requires continuous effort and adaptation to evolving threats, not a one-off project.

A simple definition of cybersecurity

Protecting Information and Systems

Cybersecurity involves safeguarding data and technology assets from unauthorized access, disruption, and manipulation to ensure business continuity and trust.

What could go wrong ?

Focus on Risk Reduction

Rather than aiming for perfect security, cybersecurity strives to reduce risks to acceptable levels aligned with business goals and resource constraints.

Compare to physical world

Manager-Friendly Perspective

Cybersecurity is not just a technical issue but a management responsibility, emphasizing strategic decision-making to balance risks and business objectives.

Manage as any other key business interest

Operational Risks Also Matter

Risks can arise from operational errors, staff mistakes, or process failures, highlighting the need for comprehensive risk management beyond just technical defenses.

Mistakes do also still happen

Cybersecurity vs IT security vs Information security

01
Information Security

Protects information in any form—digital, physical, or intellectual—from unauthorized access, disclosure, alteration, or destruction.

02
IT Security

Focuses on securing IT systems, including hardware, software, and networks, to ensure confidentiality, integrity, and availability of information technology assets.

03
Cybersecurity

Specifically protects digital systems and data in hostile environments where active, intelligent adversaries attempt to exploit vulnerabilities.

Definiton of information security according to ISO 2700:

"Preservation of confidentiality, integrity and availability of information."

Definition of cyber security according to NIST 800-53:

"The ability to protect or defend the use of cyberspace from cyber attacks."

Why organizations get hacked – they are vulnerable

Complex environments

Modern organizations have interconnected systems that create vulnerabilities and increase attack surfaces.

Time pressure & trade-offs

Managers and IT teams often balance speed and functionality with security, leading to risk acceptance.

Legacy systems

Older technology may lack updates or support, creating exploitable security gaps that remain unpatched.

Human behavior

Phishing, errors, and weak password practices by employees expose organizations to cyber threats.

Business decisions

Risky choices like outsourcing or inadequate investment in security can open doors for attackers.

Why organizations are targeted – they are a point of interest

Financial motivations

Cyber criminals might want to steal money, either directly or indirectly, through extortion and ransom. More often nation-state affiliated hacker groups need to self-fund and also act upon this motivation.

Theft of intellectual property

Some organization's value is not in money but in intellectual property. This can make that organization an interesting target.

Theft of otherwise sensitive info

Some organizations hold sensitive information of (large groups of) private individuals, or of other organizations. Parties might be interested in this information, for a variety of reasons.

Break down society

Countries, terrorists and other actors might want to break down society. If the organization plays a vital role in society, this might make you a target.

Damage image of the organization

Hacktivists might not like the operating model or actions of certain organizations. They may be angry, and this too can make you a target.

The attacker's advantage

Single Success Needed

Attackers only need to succeed once to cause damage, whereas defenders must prevent every attack continuously.

Constant Defense Required

Defenders must maintain vigilance 24/7 to block all attempts, making defense resource-intensive and exhausting.

Scalable Attacks

Attackers can launch automated, large-scale attacks at low cost, multiplying their chances of success.

Limited Defender Resources

Budget constraints, limited personnel, and usability needs restrict defenders' ability to respond effectively.

Cyber risk as a business risk

Comparable to Financial Risk

Cyber risk can lead to significant financial losses through theft, fraud, and recovery costs, similar to traditional financial risks organizations face.

Comparable to Legal Risk

Regulatory fines, breach notification requirements, and contractual liabilities make cyber risk a critical legal concern for organizations.

Comparable to Supply Chain Risk

Vulnerabilities in third-party vendors and partners can propagate cyber threats, mirroring supply chain disruptions in business operations.

Comparable to Operational Risk

Cyber incidents can disrupt business processes, halt production, and impact service delivery, causing operational challenges.

Different elements play a role in determining risk profile

1. Value that is present within the organization
2. Sector / role of the organization
3. External threat developments, who is doing what
4. Level of technical and organizational complexity
5. Level of management awareness and available budget
6. Level of expertise within the delivery organization
7. Quality of defensive measures taken

The CIA triad explained

or

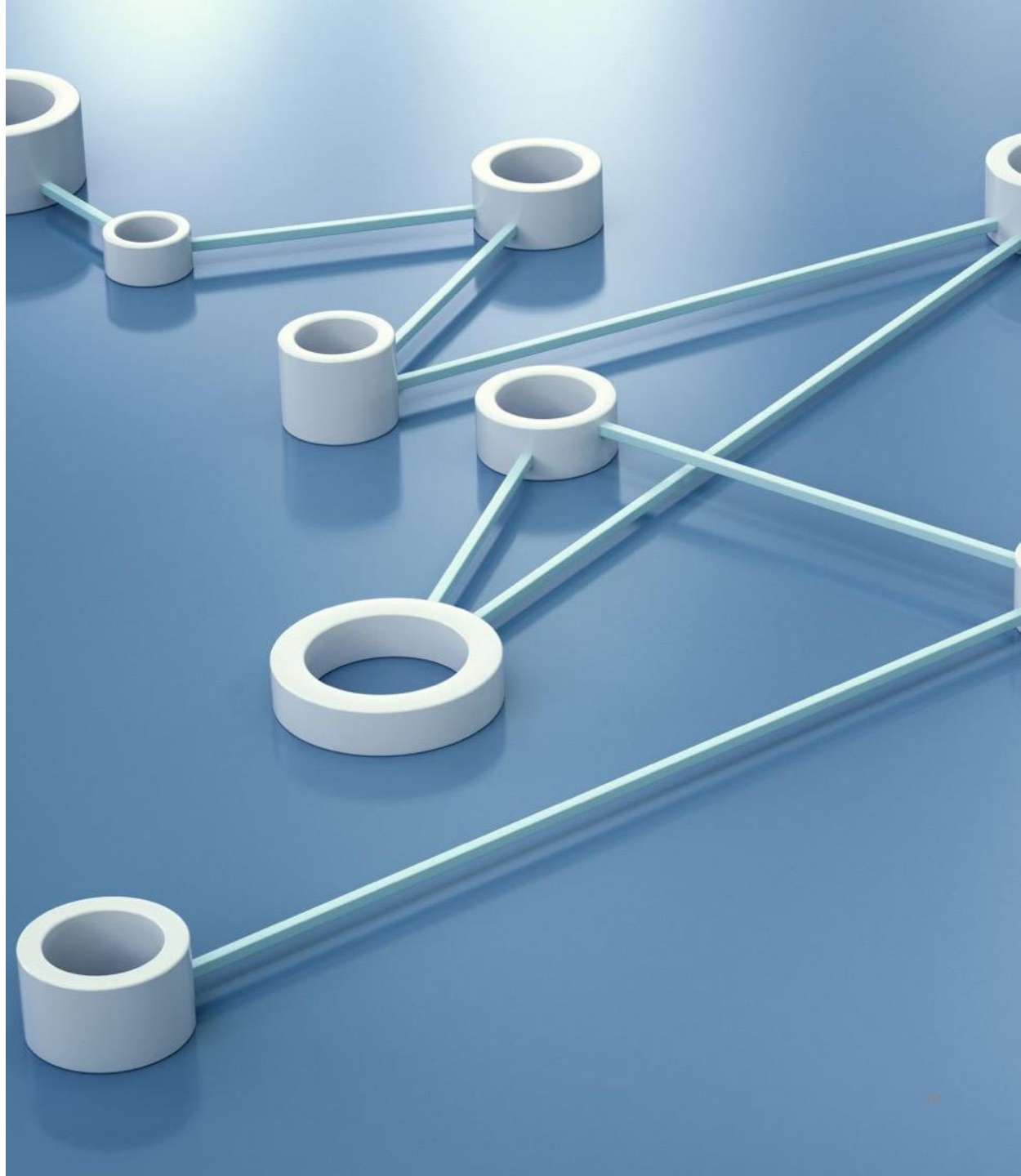
the identification of value within an organization

Confidentiality	Ensures that sensitive data is accessed only by authorized individuals, supporting trust and compliance obligations such as privacy regulations.
Integrity	Guarantees that information remains accurate and unaltered, which is essential for maintaining decision quality and reliable business processes.
Availability	Ensures systems and data are accessible when needed, critical for business continuity, revenue generation, and operational stability.
Relation to Privacy	Maintaining confidentiality supports privacy laws and safeguards customer and employee information from unauthorized exposure.
Business Continuity	Availability directly impacts the ability to operate without interruption, highlighting the importance of cybersecurity in minimizing downtime risks.

Sector or role of the organization

Consider the following examples, why would these be of interest to cyber criminals ?

- Energy provider
- Energy network manager
- Local SME production company
- Innovative tech company
- Chemical company
- Aid relief organization
- Bank
- School
- Police department
- Sexual content provider



Types of information and cyber security threats overview

External Attackers

These are hackers or cybercriminals outside the organization who exploit vulnerabilities to steal data, disrupt operations, or demand ransom.

Insiders

Threats can come from employees or contractors, whether through malicious intent or accidental mistakes that expose systems and data.

Partners and Suppliers

Vendors and third-party service providers can introduce risks if their cybersecurity is weak, impacting your organization indirectly.

Accidental Failures

Human errors, system misconfigurations, or software bugs can unintentionally create security gaps leading to incidents.

Malware & ransomware

Ransomware Mechanics

Ransomware encrypts critical systems and data, making them inaccessible until a ransom is paid. It primarily targets system availability to maximize pressure on organizations.

Business Model

Attackers leverage speed and urgency, demanding quick ransom payments to restore access, often exploiting operational disruption for financial gain.

Management Focus

Effective management involves robust backup strategies, regular testing of restore procedures, and having a clear incident response plan to minimize downtime.

Crisis Decision-Making

During a ransomware event, leaders must make rapid decisions balancing operational continuity, legal considerations, and communication with stakeholders.

Phishing & social engineering

Attack Methods

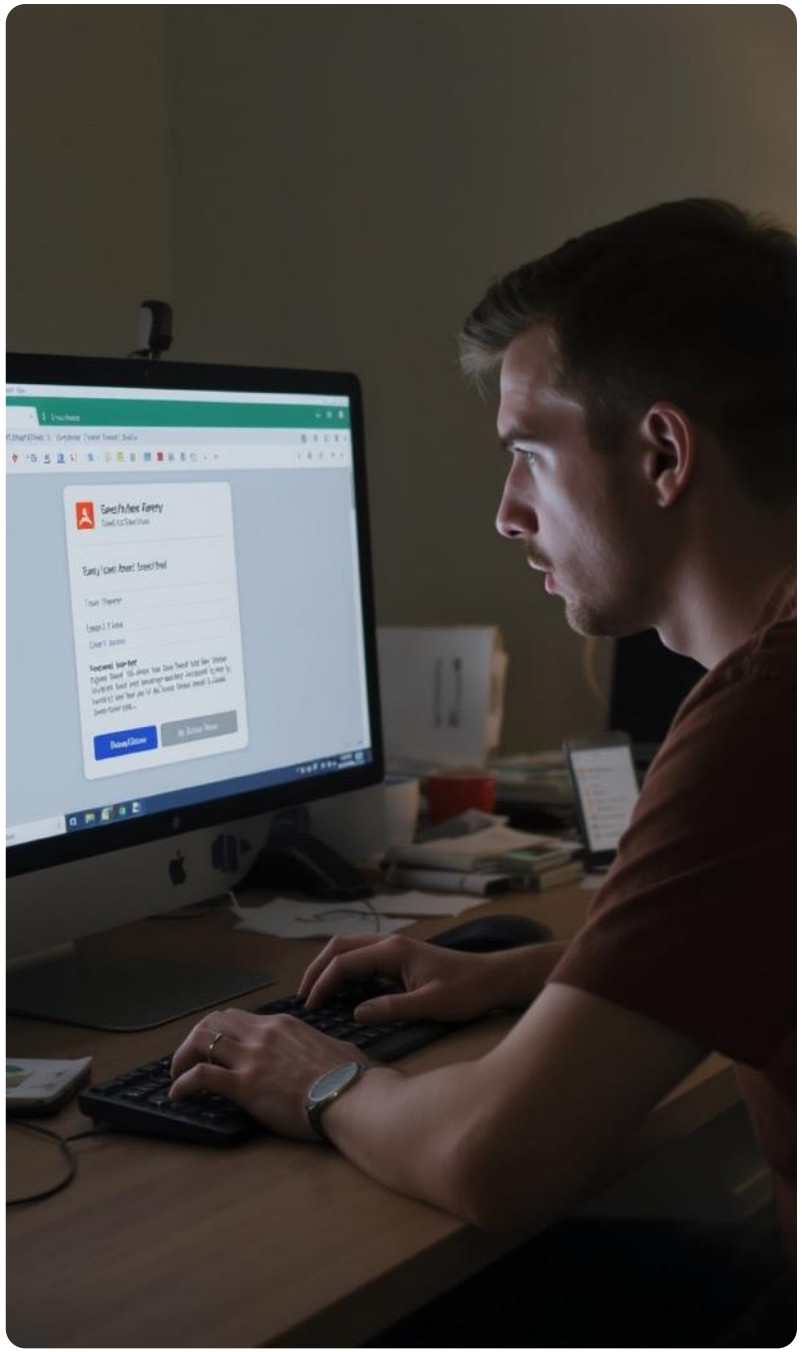
Phishing attacks use email, SMS, voice calls, and even deepfake technology to deceive individuals into revealing sensitive information or performing unsafe actions.

Psychological Exploits

Attackers exploit human traits like authority, urgency, and curiosity to trick targets into bypassing security protocols or sharing confidential data.

Effectiveness in Secure Environments

Even in organizations with strong technical defenses, social engineering remains highly effective because it targets people rather than systems.



Insider threats

Disgruntled Employees

Employees with grievances may intentionally cause damage or steal data, motivated by dissatisfaction or retaliation.

Careless Behavior

Unintentional actions like clicking phishing links or misconfiguring systems can create serious vulnerabilities.

Excessive Access Rights

Over-privileged accounts increase risk exposure by enabling unauthorized data access or changes.

Lack of Monitoring

Insufficient oversight and auditing allow insider threats to persist undetected and escalate.

Third-party & supply chain risk

01

Cloud Providers

Relying on cloud services introduces risks related to data storage, access control, and shared infrastructure vulnerabilities that must be managed through thorough vendor assessment and monitoring.

02

Software Suppliers

Third-party software can carry hidden vulnerabilities or malicious code; rigorous evaluation, patch management, and supply chain security are essential to reduce exposure.

03

Outsourced Services

Services like IT support or customer management can create entry points for cyber threats if not tightly controlled and audited regularly for compliance and security.

04

Data Processors

Entities handling sensitive data must adhere to strict security standards and contractual obligations, as breaches here directly impact confidentiality and regulatory compliance.

Financial impact of cyber incidents

01

Incident Response & Recovery Costs

Expenses include forensic analysis, system restoration, legal fees, and communication efforts to manage the aftermath of a cyber incident.

02

Ransom Payments

Some organizations pay ransoms to regain access to encrypted data, which can be costly and does not guarantee full recovery.

03

Lost Revenue

Operational downtime and disrupted services during and after an attack lead to significant revenue losses, affecting overall business performance.

04

Increased Insurance Premiums

Cyber incidents often result in higher premiums for cybersecurity insurance policies, adding to ongoing operational costs.

Operational disruption

Production Halts

System outages can stop manufacturing lines or service delivery, causing delays and lost productivity that ripple through the supply chain.

Logistics Failures

Disrupted IT systems impair inventory management and transportation coordination, leading to shipment delays and increased operational costs.

Inability to Serve Customers

Downtime prevents access to online services, sales platforms, and customer support, damaging customer experience and trust.

Manual Workarounds

When systems fail, staff resort to slower, error-prone manual processes that reduce efficiency and increase risk of mistakes.

Legal and regulatory consequences

01

GDPR Fines

Non-compliance with data protection laws like GDPR can result in heavy fines reaching up to 4% of annual global turnover or €20 million, whichever is higher.

02

Mandatory Breach Notification

Organizations must promptly report data breaches to authorities and affected individuals, often within strict timeframes such as 72 hours under GDPR.

03

Contractual Liability

Failure to meet cybersecurity standards can lead to breach of contract claims, penalties, and loss of business with partners and clients.

04

Director Responsibility

Company directors and executives face personal liability risks for failing to oversee adequate cybersecurity governance and compliance.

Reputational damage

01 Customer churn

Cyber incidents cause loss of customer trust, leading to increased churn as clients seek more secure alternatives.

02 Brand damage

Negative publicity from breaches tarnishes brand image and can diminish market value and competitive positioning.

03 Media scrutiny

High-profile cyber events attract intense media attention, amplifying reputational harm and public criticism.

04 Long recovery timelines

Restoring trust and rebuilding reputation can take years, requiring consistent transparency and improved security measures.

There is a difference between cause and effect

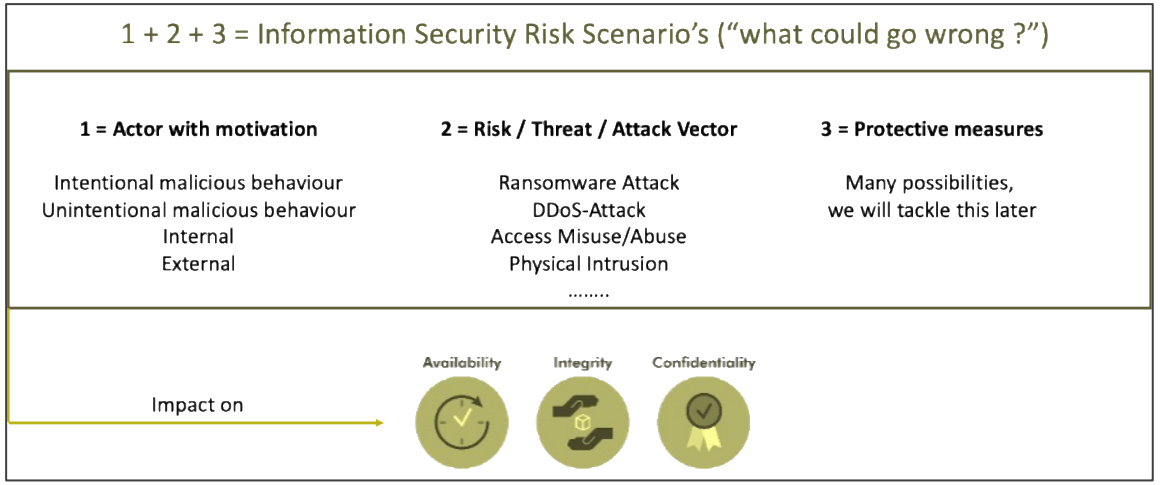
1 + 2 + 3 = Information Security Risk Scenario's ("what could go wrong ?")

1 = Actor with motivation	2 = Risk / Threat / Attack Vector	3 = Protective measures
Intentional malicious behaviour Unintentional malicious behaviour Internal External	Ransomware Attack DDoS-Attack Access Misuse/Abuse Physical Intrusion ……..	Many possibilities, we will tackle this later

Impact on

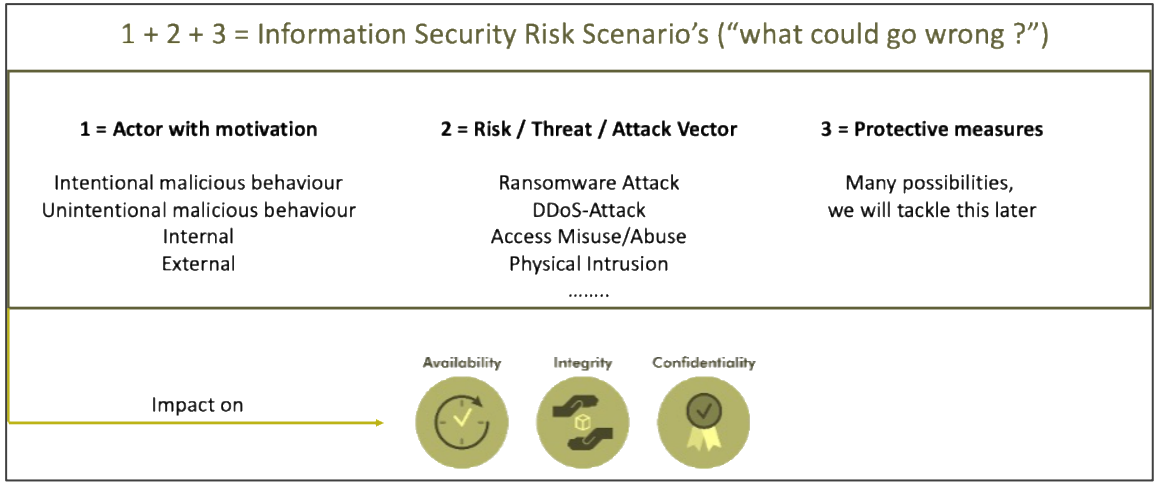
Example 1

- Insider – disgruntled employee
- Abuses access
- Which goes unnoticed as it seems to be approved access
- To steal sensitive data and email it out
- To then blackmail the organization
- Which is a breach of confidentiality
- Which could lead to financial loss and reputational risk



Example 2

- External vendor-employed IT employee
- Is notified to log in to remotely resolve an IT issue
- He / she bypassed 4-eyes principle procedure and directly logs in the customer database
- To make amendments in the database which corrupts the data
- Which is a breach of integrity
- Which could lead to financial loss, operational and reputational impact



Example 3

- External hacker group
- Aiming to make some money
- Launches a DDoS-attack on a successful SME-organization
- Which brings down a lucrative webshop
- Which is not able to recovery quickly as it did not prepare for this
- A ransom is asked and paid
- After which service is restored (or not)
- This is a breach of availability
- With financial, operational and reputational impact

1 + 2 + 3 = Information Security Risk Scenario's ("what could go wrong ?")

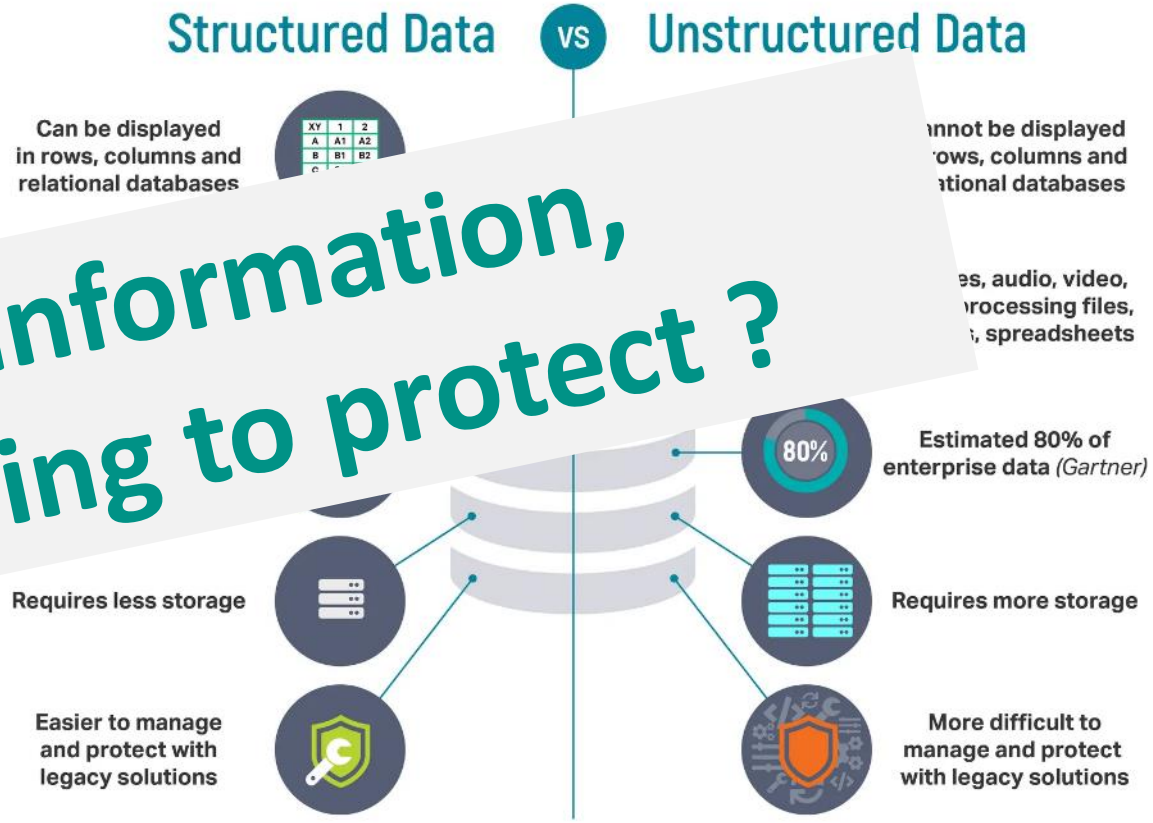
1 = Actor with motivation	2 = Risk / Threat / Attack Vector	3 = Protective measures
Intentional malicious behaviour Unintentional malicious behaviour Internal External	Ransomware Attack DDoS-Attack Access Misuse/Abuse Physical Intrusion	Many possibilities, we will tackle this later

Impact on

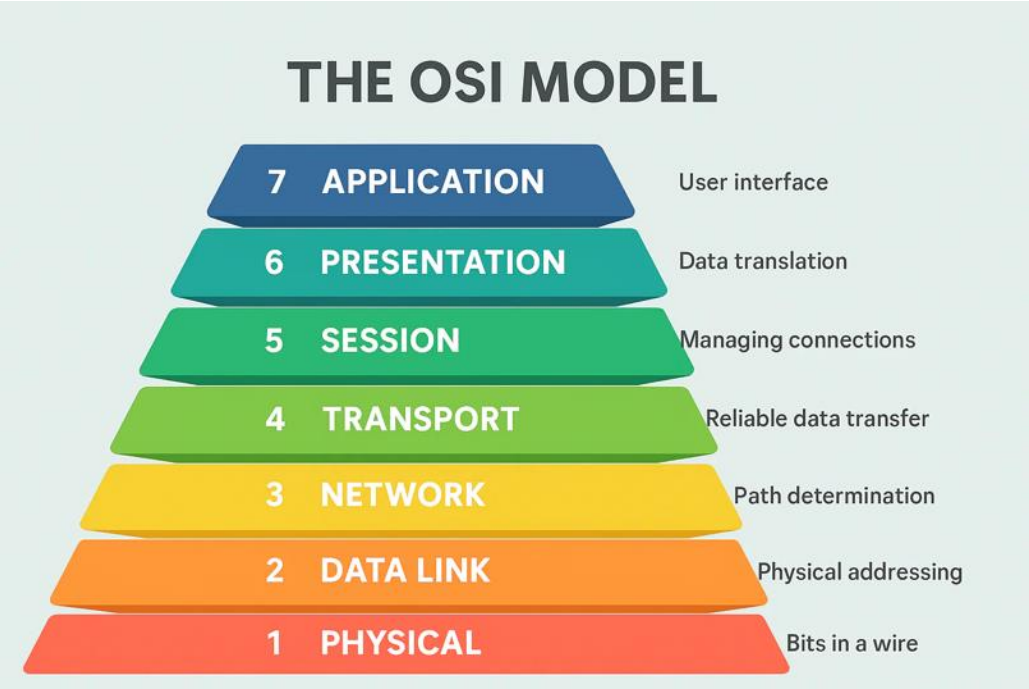
So, why is this complex ? Information challenge

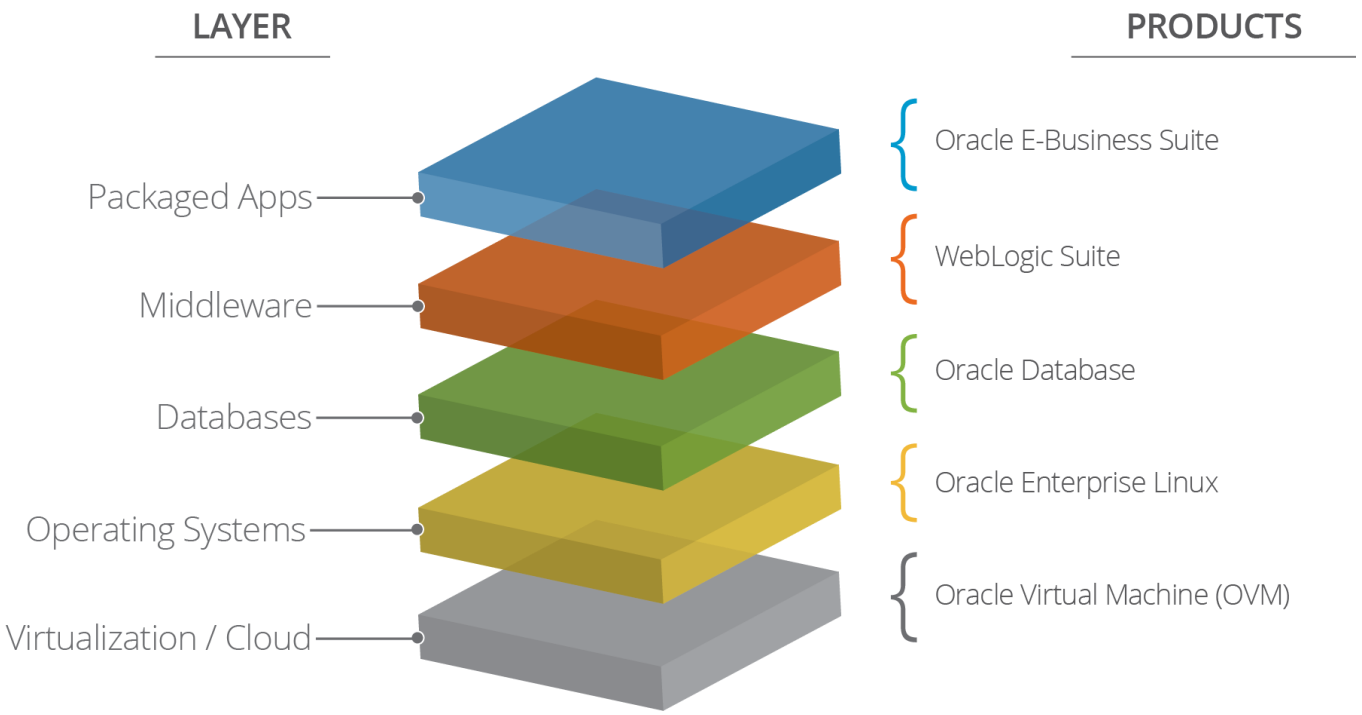
- Organizations process huge volumes of data / information
- It is typically not clear what information is stored where
- Data is not static, but (1) changes constantl
  (2) moves around all the time
- Protection
  AIC-cri

What is 'our' information, what are we trying to protect ?



So, why is this complex ? Information technology challenge 1





So, why is this complex ? Information technology challenge 2

What is ‘our’ information technology,
what are we trying to protect ?

has been

cations,
ating

digital)
and

So, why is this complex ? Information protection challenge

Organizational Information Security

1. Governance

- Inf. Security Policies & Standards
- Inf. Security Risk & Compliance
- Inf. Security Metrics & Reporting
- Inf. Security Strategy
- Inf. Security Organization

2. Identify

- Asset Classification
- Asset Inventory
- Threat Identification
- Third-party Security Risk Mgmt
- Vulnerability Management
- Red Teaming
- Penetration Testing
- Physical Security Risk Mgmt

3. Protect

- Identity Management Employee
- Authentication Employee
- Authorisation Employee & Role Mgmt
- Privileged Access Management
- API Security
- Network Security
- Data Encryption & Key Mgmt
- Secure Configuration
- Secure Code
- Endpoint Protection
- DDoS Protection
- Data Loss Prevention
- Inf. Security Awareness & Training

4. Detect

- Infra Security Logging & Monitoring
- Appl. Security Logging & Monitoring
- Notice & Take Down
- Shadow IT

5. Respond

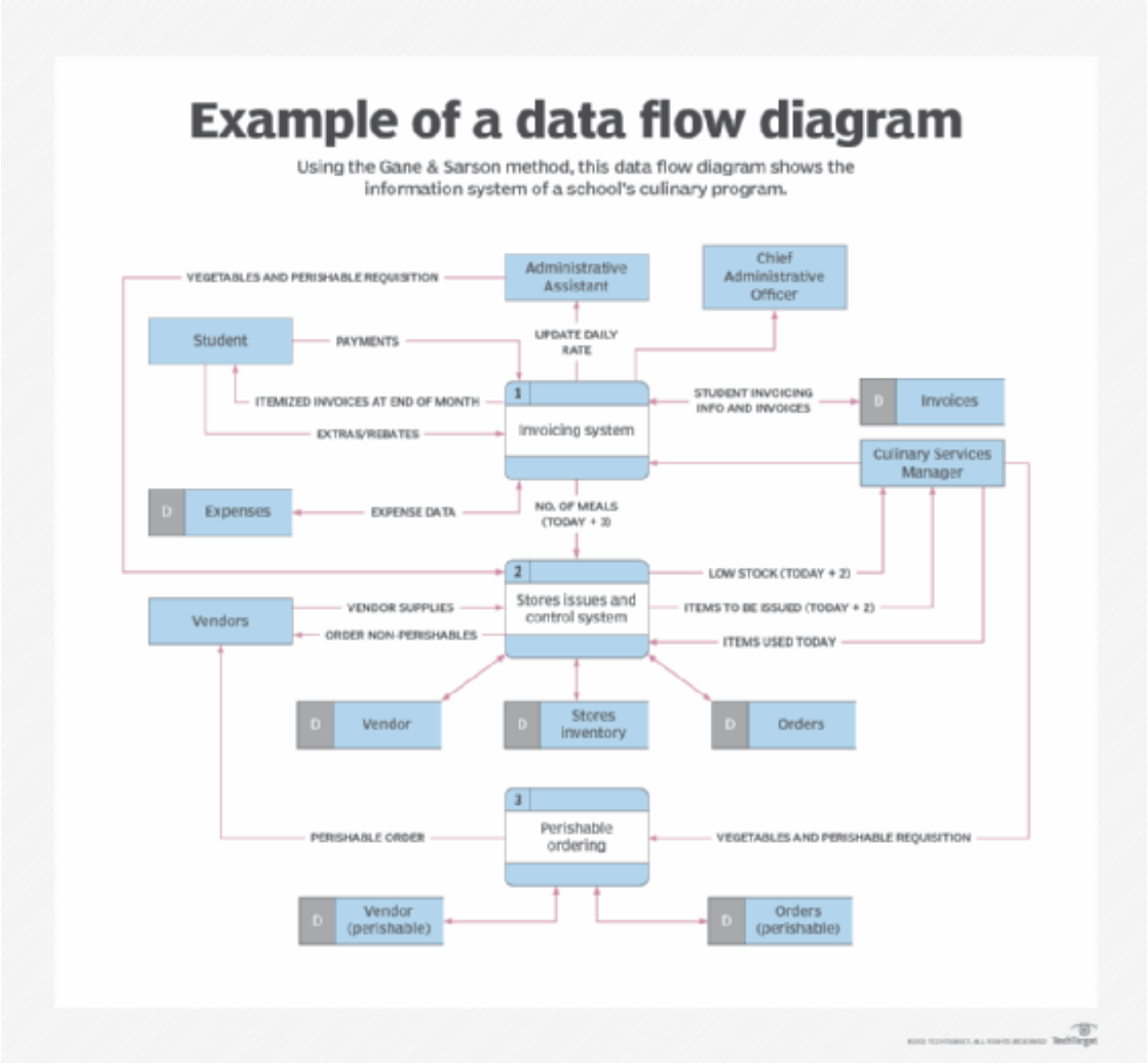
- Inf. Security Incident Response
- Inf. Security Issue Management

6. Recover

- Cyber Recovery

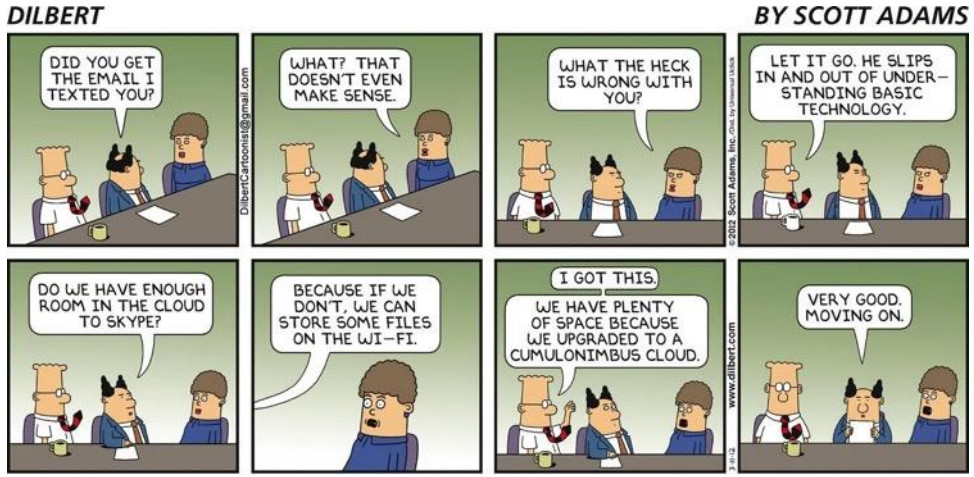
So, why is this complex ? Process change complexity challenge

- Processes have multiple steps, often with multiple options, quickly becoming a full tree of process steps
- In a more complex process multiple IT systems play a role
- Nowadays, process steps and / or IT used are a mix of internal and outsourced activities
- And typically organizations and IT systems change continuously, making a business process a complex and fluid whole of complexity
- Which many users do not oversee
- Hackers only need to find a weak spot



So, why is this complex ? Human understanding challenge

- Many people do not understand technology fully, from a technical design perspective
- But how can you protect or manage something you do not understand
- Or how can you use something safely that you do not fully understand
- And to be fair, much IT is overly complicated.



“

Complexity is the worst enemy of security, and our systems are getting more complex all the time

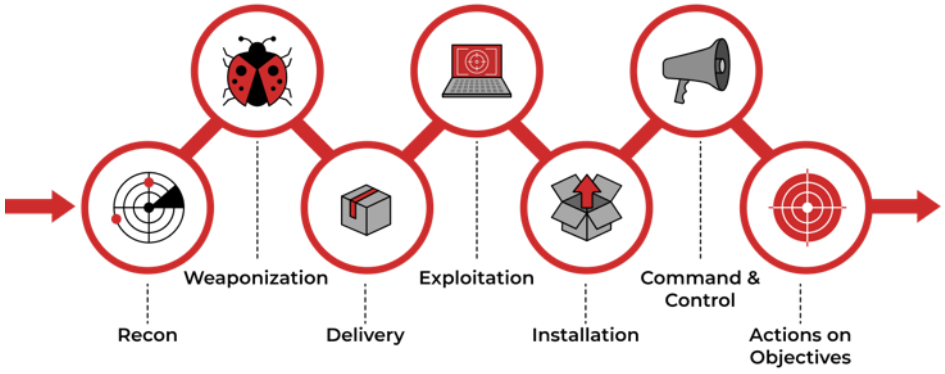
”

— Bruce Schneier

Frameworks to analyze cyber attacks

Cyber Kill Chain

- Teaching **how attacks build up over time**
- Showing **where an attack can be disrupted**
- Explaining attacks as a **campaign**, not a single event



MITRE ATT&CK Framework

- Mapping **real-world attacker behavior**
- Detection engineering & threat hunting
- Red team / blue team alignment
- Modern attacks (identity, cloud, SaaS)

1. Cyber Kill Chain explains the sequence of an attack from start to finish.
2. MITRE ATT&CK explains the techniques attackers use at each step of that attack.
3. Think flow vs. detail.

100% Security is mostly a superstition.
It does not exist in nature.

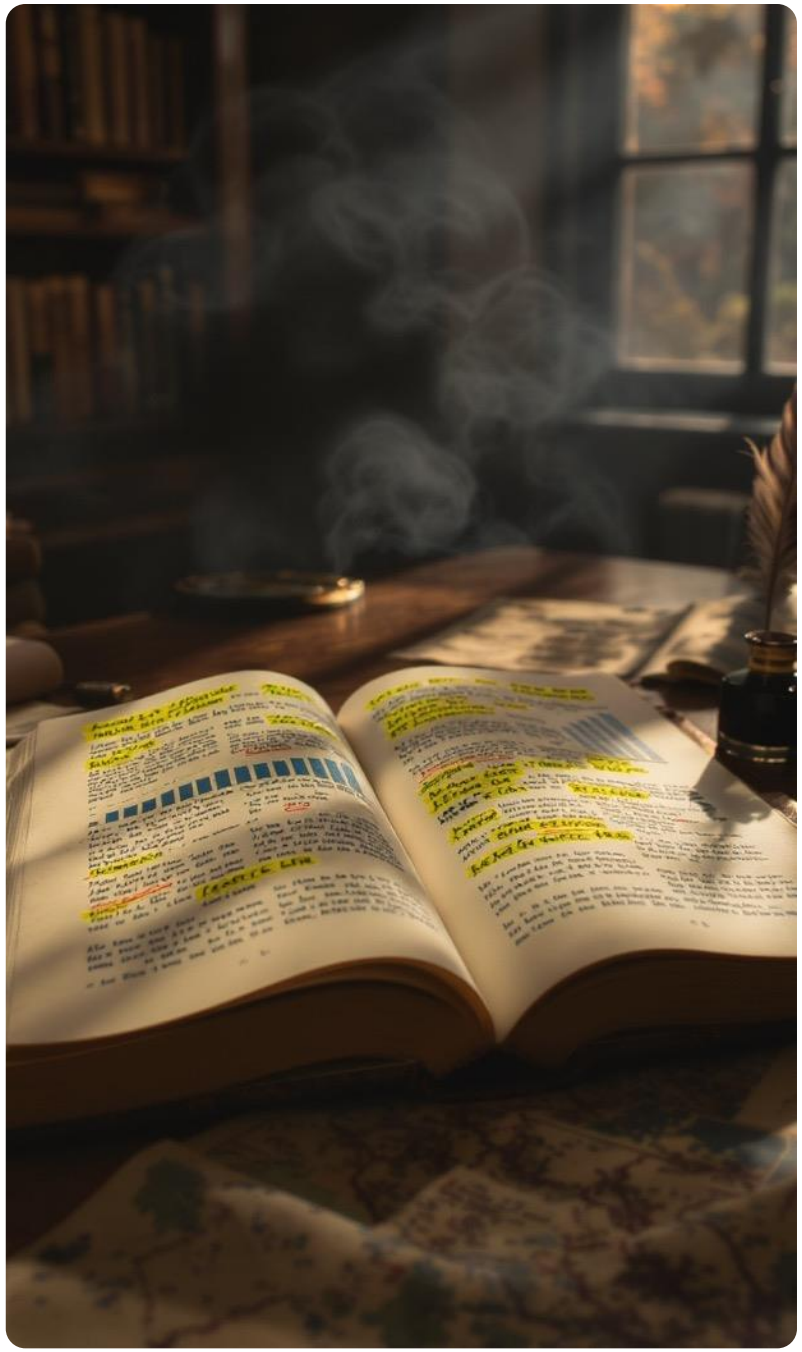
Helen Keller

quotefancy

Security is not the absence of danger, but the presence of preparedness.

Why case studies matter

Cybersecurity case studies are valuable because they reveal patterns that frequently recur across incidents, such as deferred decisions, overlooked controls, and common vulnerabilities. Understanding these root causes helps managers anticipate predictable outcomes and avoid similar mistakes in their own organizations. By analyzing real-world breaches, managers gain insights into the governance and operational factors behind failures, reinforcing that many incidents are not due to unknown threats, but known risks left unaddressed. This knowledge is crucial for proactive risk management and continuous improvement.



Case: Jaguar Land Rover – what happened ?

- **Initial access appears driven by stolen credentials** harvested via infostealer malware.
- *First data collected through SaaS-applications ?*
- **Lateral movement across internal networks** enabled access to core IT systems supporting production and operations.
- *Entry to the network through phishing, or perhaps through connected applications ?*
- **Company took systems offline** to contain the breach, leading to prolonged production stoppage.
- **Threat actor claims responsibility** via social channels, though official attribution remains under investigation.
- **Data exfiltration** included sensitive internal and employee data.

Case: MGM Resorts International

1. Reconnaissance (OSINT)
- Attackers gathered employee names, roles, and structure from public sources (e.g. LinkedIn)

2. Initial Access – Social Engineering
- Attackers called the IT helpdesk, impersonating an employee
- Used personal details to pass identity checks
- Convinced staff to reset MFA for the account

3. Credential Abuse
- Logged in with valid credentials
- Access appeared legitimate → no immediate alerts
- No malware or technical exploit required

4. Privilege Escalation
- Enumerated internal systems and identity roles
- Exploited misconfigurations to gain admin privileges

5. Lateral Movement
- Used built-in admin tools ("living off the land")
- Moved through Active Directory and core IT systems
- Reached systems supporting hotel and casino operations

6. Payload & Disruption
- Ransomware deployed only after broad control
- Encryption and system shutdowns caused operational collapse

Key Lesson:
1. **Ransomware was the final step — identity compromise and lateral movement enabled the attack.**
2. **Humans + identity systems are now the primary attack surface.**

Who gets blamed?

When a cybersecurity incident occurs, the blame often extends beyond technical defenses like firewalls and antivirus software. Ultimately, responsibility lies with management decisions and the governance frameworks they establish. Effective cybersecurity depends on leadership prioritizing risk management, allocating resources appropriately, and fostering a culture of security awareness. Failure to do so transforms cyber incidents into stories of governance lapses rather than mere technical shortcomings. This underscores how managerial oversight and decision-making shape the organization's resilience against cyber threats.

What managers should NOT do

01 Delegate blindly

Avoid handing off cybersecurity entirely to IT without oversight. Managers must stay informed and engaged to ensure effective risk management.

02 Ignore bad news

Do not dismiss or hide security incidents or vulnerabilities. Transparency and early action are critical to minimizing damage.

03 Over-focus on tools

Relying solely on technology solutions without proper governance and policies leads to gaps in security posture.

04 Treat security as a project

Cybersecurity is a continuous process, not a one-time task. Ongoing management and adaptation are essential to keep up with evolving threats.

What managers SHOULD do

01 Ask the Right Questions

Engage with cybersecurity experts and teams by asking targeted questions about risks, controls, and incident scenarios to maintain informed oversight.

02 Prioritize Critical Assets

Identify and focus protection efforts on the most valuable and vulnerable business assets, including data, systems, and processes crucial to operations.

03 Fund Resilience, Not Perfection

Invest resources in building robust, adaptable cybersecurity measures that maintain business continuity rather than chasing unattainable perfect security.

04 Prepare for Incidents

Develop and regularly update incident response plans, conduct drills, and ensure teams are ready to act swiftly when cyber events occur.

Cybersecurity is a critical business risk that impacts every part of the organization, not just an IT issue.

Managers must understand that cybersecurity influences financial stability, reputation, legal compliance, and operational continuity. Effective risk management requires leadership involvement beyond the IT department to align security with business objectives and strategy. It is essential to integrate cybersecurity into overall risk management rather than isolating it as a technical issue.